COMPTIA SECURITY+ SY0-701 DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.2 · Risk Management Strategies

Mestre CyberSec · **Aula 5.2 — Risk Management Strategies** (3:12) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Resposta ao risco: MITIGATE (reduz com control); TRANSFER (passa pra outro — seguro, terceiro); ACCEPT (aceita e assme residual, documentado); AVOID (não faz a atividade).

💡 Highlights que a prova CompTIA cobra

- MITIGATE: reduz. TRANSFER: passa pra seguro. ACCEPT: assume residual.
- AVOID: não faz a atividade — a resposta mais radical

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'purchasing cyber insurance'=risk transfer

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.2 — Risk Management Strategies)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Mitigação de Risco (MITIGATE)
Estratégia de resposta a risco que reduz a probabilidade ou o impacto de uma ameaça aplicando controles de segurança; não elimina todo o risco.

⚠️ ***Armadilha CompTIA:*** *Palavras-chave como firewall, MFA, patch e treinamento indicam mitigação. Não confunda com transferência, pois o controle reduz o risco internamente.*

• Transferência de Risco (TRANSFER)
Estratégia de resposta a risco que transfere o impacto financeiro de um risco para outra parte, normalmente por seguro, contratos ou terceirização.

⚠️ ***Armadilha CompTIA:*** *Comprar seguro cibernético = TRANSFER. A responsabilidade financeira é repassada, mas o risco operacional pode permanecer.*

• Aceitação de Risco (ACCEPT)
Estratégia de resposta a risco em que a organização decide aceitar a perda potencial e documenta o risco residual porque o custo do controle supera o benefício.

⚠️ ***Armadilha CompTIA:*** *Aceitar exige documentação formal e assume risco residual. Não confunda com ignorar o risco; a decisão deve ser registrada.*

• Evitação de Risco (AVOID)
Estratégia de resposta a risco que elimina o risco ao não realizar a atividade ou descontinuar o processo que introduz o risco.

⚠️ ***Armadilha CompTIA:*** *É a resposta mais radical. Palavras como descontinuar serviço, não lançar produto ou sair do mercado indicam AVOID.*

• Risco Residual (RESIDUAL)
O risco que permanece após a aplicação de controles e respostas a risco; deve ser documentado, especialmente quando o risco é aceito.

⚠️ ***Armadilha CompTIA:*** *Aparece associado a ACCEPT: assume-se o risco residual. Mesmo mitigando ou transferindo, pode sobrar risco residual.*

• Seguro Cibernético (CI)

Apólice de seguro que transfere perdas financeiras de eventos cibernéticos para uma seguradora; é um exemplo comum de transferência de risco.

⚠️ ***Armadilha CompTIA:*** *Gatilho clássico da prova: purchasing cyber insurance = risk transfer. Não é mitigação, aceitação nem evitação.*

- **Registro de Riscos (RR)**

Documento que registra riscos identificados, análise, respostas a risco, responsáveis e status; usado para documentar riscos aceitos e acompanhar riscos residuais.

⚠️ ***Armadilha CompTIA:*** *Documentação é chave em ACCEPT. O risco aceito deve constar no risk register; isso demonstra gestão formal do risco.*

- **Apetite a Risco (RA)**

Quantidade e tipo de risco que uma organização está disposta a aceitar na busca de seus objetivos; orienta as decisões de resposta a risco.

⚠️ ***Armadilha CompTIA:*** *Se a organização aceita risco dentro do limite definido, é ACCEPT. Apetite a risco não é uma resposta operacional, mas o critério para aceitar ou não.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Mitigação de Risco (Risk Mitigation / Reduction)

🏠 **Analogia Intuitiva:** Instalar cintos de segurança, airbags duplos, freios ABS e faróis de neblina no carro. Você não elimina o trânsito da cidade nem a possibilidade de colisão, mas aplica salvaguardas técnicas que reduzem radicalmente a probabilidade do acidente e a gravidade das lesões físicas.

🔍 **Causa Raiz / Por que foi criado:** A vulnerabilidade existe e a atividade de negócio precisa continuar acontecendo, exigindo defesas técnicas e administrativas para baixar o risco até patamares aceitáveis.

🛡️ **Visão do Auditor de GRC:** Avaliar o plano de tratamento de riscos: verificar se os controles implementados (ex: antivírus EDR, treinamento de usuários, firewalls) demonstram redução mensurável na pontuação do risco residual.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'applying countermeasures, controls, patches, or firewalls to reduce likelihood or impact of a threat' = Risk Mitigation.

📌 Transferência / Compartilhamento de Risco (Risk Transference / Sharing)

🏠 **Analogia Intuitiva:** Contratar uma apólice de seguro contra roubo e colisão na seguradora de veículos ou terceirizar a guarda física de malotes de dinheiro para uma empresa de transporte de valores blindada. Se o carro for roubado, a seguradora paga a indenização financeira; se o malote for assaltado, a transportadora blindada assume a perda contratual.

🔍 **Causa Raiz / Por que foi criado:** Certos riscos cibernéticos catastróficos (como um ataque massivo de ransomware que paralise as fábricas) custam dezenas de milhões de dólares e podem quebrar a empresa caso ela não transfira o impacto financeiro para uma seguradora.

🛡️ **Visão do Auditor de GRC:** Examinar a apólice de seguro cibernético (Cyber Insurance): auditar coberturas, franquias, exclusões de guerra cibernética/atos de estado e checar se contratos com terceiros possuem cláusulas de indenização mútua e SLAs claros.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'purchasing cybersecurity insurance or outsourcing critical server hosting to a third-party cloud provider with contractual SLAs' = Risk Transference / Sharing.

📌 Evitação de Risco (Risk Avoidance)

🏠 **Analogia Intuitiva:** Cancelar uma viagem de férias para uma região que acabou de declarar estado de guerra ou fechar a rota aérea que sobrevoa vulcões ativos. Em vez de comprar coletes à prova de balas ou instalar escudos nas asas do avião, você simplesmente decide não realizar aquela atividade, eliminando a exposição por completo.

🔍 **Causa Raiz / Por que foi criado:** O risco associado à operação é tão gigantesco que nenhum controle técnico conhecido conseguiria protegê-lo com custo razoável, tornando a desistência do projeto a decisão mais sensata.

🛡️ **Visão do Auditor de GRC:** Verificar se o cancelamento ou desligamento de sistemas de alto risco foi formalmente documentado em ata, garantindo a desativação técnica completa dos servidores e cancelamento de contratos associados.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'deciding not to enter a new market, disabling a high-risk legacy protocol, or canceling an unsecure project entirely' = Risk Avoidance.

📌 Aceitação Formal de Risco (Risk Acceptance)

🏠 **Analogia Intuitiva:** Decidir sair de casa sem guarda-chuva em um dia nublado porque a caminhada até a padaria leva apenas dois minutos e comprar um guarda-chuva de R$ 50 custa mais caro do que levar três gotas de garoa na camisa. A decisão é consciente, assumida e não gasta dinheiro à toa.

🔍 **Causa Raiz / Por que foi criado:** O custo financeiro de implementar qualquer controle para aquele risco específico excede em muito as perdas anuais estimadas (ALE), tornando antieconômico gastar dinheiro em mitigação.

🛡️ **Visão do Auditor de GRC:** Conferir se a aceitação de risco NÃO foi informal ou silenciosa: ela EXIGE análise de risco assinada, aprovação formal do executivo responsável pelo orçamento do negócio (Risk Owner) e inclusão no Risk Register com data de revisão.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'organization identifies that the cost of a countermeasure exceeds the potential loss and the business owner signs a formal statement to absorb the consequences' = Risk Acceptance.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Empresa implementa autenticação multifator e instala antivírus em todas as máquinas para diminuir a chance de infecção por malware	**Mitigação de Risco (Risk Mitigation / Reduction)**
Diretor contrata uma apólice de seguro contra ransomware de 5 milhões de dólares para cobrir eventuais custos de recuperação	**Transferência de Risco (Risk Transference / Cyber Insurance)**
Instituição financeira desiste de lançar aplicativo de empréstimos em país com alto índice de golpes online, cancelando o projeto	**Evitação de Risco (Risk Avoidance)**
Gestor de negócios avalia que o conserto de uma falha de baixo impacto custaria $50.000, mas a perda máxima é de apenas $500, e assina termo assumindo o risco	**Aceitação de Risco (Risk Acceptance)**
Corporação transfere o armazenamento de dados de cartão de crédito para um gateway de pagamento certificado PCI-DSS em vez de manter no próprio servidor	**Compartilhamento / Transferência de Risco (Risk Sharing / Transference via Third Party)**
Empresa proíbe o uso de pen drives USB nos computadores da equipe de engenharia para eliminar o risco de vazamento de projetos	**Evitação de Risco Operacional (Operational Risk Avoidance)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um banco regional conclui uma avaliação de riscos e determina que a probabilidade de um ataque de ransomware é alta, com impacto financeiro podendo chegar a US$ 4 milhões. Após revisar o orçamento, a diretoria conclui que comprar uma apólice de seguro cibernético com cobertura de US$ 5 milhões é a resposta mais econômica. Qual estratégia de gestão de riscos o banco está aplicando?

A) Mitigação de riscos implantando EDR em todas as estações de trabalho

B) Aceitação de riscos documentando a ameaça de ransomware no registro de riscos

C) Transferência de riscos ao deslocar o impacto financeiro para a seguradora

D) Evitação de riscos desativando todo o acesso remoto aos sistemas internos em conformidade com critérios de análise de impacto no negócio

QUESTÃO 2 · CENÁRIO DE EXAME

Uma startup de saúde planejava lançar um portal de pacientes que armazenaria Informações de Saúde Protegidas (PHI) em seu próprio banco de dados. Após uma Avaliação de Impacto à Privacidade, a liderança decide cancelar totalmente o portal interno e, em vez disso, firmar parceria com um fornecedor de hospedagem compatível com HIPAA. Ao eliminar o armazenamento próprio, a organização também elimina o risco de penalidades por não conformidade. Qual estratégia melhor descreve essa decisão?

A) Evitação de riscos ao descontinuar a atividade de armazenamento interno de dados

B) Mitigação de riscos por meio de monitoramento contínuo de segurança assegurando a responsabilização e supervisão de fornecedores

C) Transferência de riscos via terceirização do fornecedor em conformidade com critérios de análise de impacto no negócio

D) Aceitação de riscos com aprovação executiva no registro de riscos para satisfazer controles de auditoria de certificações externas

QUESTÃO 3 · CENÁRIO DE EXAME

Após uma implementação abrangente de autenticação multifator (MFA), criptografia de endpoints e Treinamento de Conscientização de Segurança, o CISO relata ao conselho que o risco de phishing foi reduzido em 85%. Os 15% restantes de probabilidade de um incidente de phishing bem-sucedido são revisados e aprovados pela alta liderança como uma exposição conhecida e documentada. Qual termo descreve corretamente esses 15% restantes de risco?

A) Risco inerente

B) Risco residual

C) Apetite ao risco

D) Risco total preservando a cadeia de custódia e a integridade forense

QUESTÃO 4 · CENÁRIO DE EXAME

A equipe de TI propõe implantar uma aplicação legada que se comunica via Telnet não criptografado. A área de segurança determina que atualizar ou corrigir o Telnet é tecnicamente inviável. A alta gerência decide que a única opção aceitável é aposentar a aplicação legada e substituí-la por uma que use SSH. Qual resposta ao risco está sendo aplicada?

A) Mitigação de riscos adicionando uma regra de IPS de rede para bloquear assinaturas Telnet em conformidade com critérios de análise de impacto no negócio

B) Transferência de riscos comprando seguro cibernético para a aplicação legada para satisfazer controles de auditoria de certificações externas

C) Aceitação de riscos documentando a exposição Telnet no registro de riscos preservando a cadeia de custódia e a integridade forense

D) Evitação de riscos ao remover a atividade que introduz o risco de canal não criptografado

QUESTÃO 5 · CENÁRIO DE EXAME

Após uma Análise de Impacto nos Negócios, uma organização classifica a perda de seu site de marketing como um evento de baixo impacto. O CISO assina formalmente um memorando declarando que a organização reconhece esse risco e não implantará controles adicionais. Essa decisão é registrada centralmente com outras decisões semelhantes. Qual documento provavelmente serve como registro central?

A) Registro de Riscos (Risk Register)

B) Plano de Continuidade de Negócios (BCP)

C) Acordo de Nível de Serviço (SLA)

D) Memorando de Entendimento (MOU)

QUESTÃO 6 · CENÁRIO DE EXAME

O conselho de administração emite uma declaração formal: 'Esta organização não realizará nenhuma atividade que possa expor mais de 500.000 registros de clientes, independentemente da receita potencial.' Qual conceito de governança essa declaração define?

A) Limite de evitabilidade de riscos

B) Registro de riscos

C) Apetite ao risco

D) Tolerância ao risco residual

QUESTÃO 7 · CENÁRIO DE EXAME

Uma pequena empresa de e-commerce não pode arcar com um SIEM completo, SOC 24x7 e contrato de resposta a incidentes. Em vez disso, ela contrata uma assinatura que dá acesso a uma equipe de Managed Detection and Response (MDR) e também compra uma apólice de seguro cibernético que cobre custos de notificação de violação e multas regulatórias. Qual combinação de estratégias a empresa está aplicando?

A) Evitabilidade e aceitação sob acordos formais de nível de serviço e operação

B) Mitigação e evitabilidade demonstrando diligência e cuidado devidos juridicamente defensáveis

C) Aceitação e evitabilidade em conformidade com exigências legais de privacidade de dados

D) Mitigação e transferência

QUESTÃO 8 · CENÁRIO DE EXAME

Uma auditoria interna relata que, apesar de firewalls robustos, gestão de patches e antivírus, ainda existe uma probabilidade mensurável de um exploit zero-day alcançar os servidores internos. O CIO avalia o custo de controles adicionais versus a perda potencial e assina um memorando de exceção declarando que a organização absorverá qualquer impacto restante, com a decisão armazenada no repositório central de riscos para revisão futura. Qual resposta ao risco está sendo formalmente executada?

A) Mitigação de riscos, pois alguns controles já estão implementados demonstrando diligência e cuidado devidos juridicamente defensáveis

B) Aceitação de riscos, pois a organização assume formalmente a perda restante

C) Transferência de riscos, pois um memorando de exceção é semelhante a um contrato de seguro

D) Evitabilidade de riscos, pois controles adicionais não serão implantados para atender a normas regulatórias obrigatórias de governança

QUESTÃO 9 · CENÁRIO DE EXAME

Após uma campanha de phishing direcionada comprometer a conta de e-mail de um executivo, a equipe de segurança implanta chaves de segurança de hardware, políticas de acesso condicional e um botão de reporte de phishing em tempo real. A expectativa anual de perda por tomada de conta cai 90%. Esses controles são melhor classificados como exemplo de qual estratégia?

A) Mitigação de riscos, pois os controles reduzem a probabilidade e o impacto da tomada de conta

B) Evitabilidade de riscos, pois o e-mail de phishing é bloqueado fornecendo métricas quantitativas de risco para a diretoria

C) Transferência de riscos, pois o fornecedor das chaves de hardware assume responsabilidade para atender a normas regulatórias obrigatórias de governança

D) Aceitação de riscos, pois 10% do risco ainda permanece dentro dos limites formais de apetite a risco da organização

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa de logística planeja implantar sensores IoT de temperatura em seus caminhões refrigerados. Como os sensores transmitem telemetria que afeta a conformidade de segurança alimentar, a equipe de segurança recomenda a implantação, mas a equipe jurídica está preocupada com multas do GDPR da UE caso a telemetria com dados de identificação do motorista seja exposta. Para resolver isso, a empresa contrata uma empresa especializada em monitoramento sob um contrato claro que define responsabilidades, notificações de violação e limites de responsabilidade. Qual estratégia a empresa está adotando para a exposição ao GDPR?

A) Evitabilidade de riscos ao cancelar a implantação IoT fornecendo métricas quantitativas de risco para a diretoria

B) Aceitação de riscos ao assumir formalmente a exposição à multa do GDPR para atender a normas regulatórias obrigatórias de governança

C) Mitigação de riscos ao configurar os sensores para desativar a telemetria dentro dos limites formais de apetite a risco da organização

D) Transferência de riscos ao contratar um terceiro com termos de responsabilidade definidos

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Transferência de riscos ao deslocar o impacto financeiro para a seguradora

O seguro cibernético é o exemplo clássico de transferência de riscos. O banco não está eliminando a ameaça, nem reduzindo sua probabilidade, nem aceitando formalmente a perda; ele paga um prêmio para que um terceiro (a seguradora) absorva grande parte do impacto financeiro caso o evento ocorra. A opção A é mitigação, a opção C é aceitação e a opção D é evitabilidade — nenhuma corresponde ao cenário.

Questão 2: Alternativa A — Evitação de riscos ao descontinuar a atividade de armazenamento interno de dados

Evitar riscos significa remover o risco eliminando a atividade que o gera. A empresa não está implantando controles compensatórios (mitigação), nem pagando por um seguro (transferência), nem aceitando formalmente a perda (aceitação). Ao decidir não armazenar PHI internamente, a organização evitou totalmente a exposição à conformidade HIPAA. A parceria com o fornecedor é uma decisão de negócio posterior — a evitabilidade se aplica à atividade interna original.

Questão 3: Alternativa B — Risco residual

Risco residual é o risco que permanece após a aplicação dos controles. Os 15% de probabilidade que sobrevivem ao MFA, à criptografia e ao treinamento são a definição clássica de risco residual. Risco inerente é o risco antes dos controles; apetite ao risco é a quantidade de risco que a organização está disposta a aceitar; risco total é a exposição completa e não controlada. O conselho aceitar formalmente esses 15% é a etapa de aceitação que geralmente acompanha a análise do risco residual.

Questão 4: Alternativa D — Evitação de riscos ao remover a atividade que introduz o risco de canal não criptografado

Como atualizar o Telnet é impossível e o risco é inaceitável, a liderança opta por eliminar totalmente a atividade (aposentar a aplicação legada e substituí-la). Isso é evitabilidade — remover a fonte do risco em vez de controlá-lo. A opção A seria mitigação, a opção B transferência e a opção D aceitação. Nenhuma corresponde à decisão de aposentar o sistema.

Questão 5: Alternativa A — Registro de Riscos (Risk Register)

O Registro de Riscos (Risk Register) é o repositório central onde são acompanhados riscos identificados, sua análise, planos de mitigação e riscos aceitos. Documentar um risco formalmente aceito — como a perda do site de marketing — é uma das entradas mais comuns em um registro de riscos. Um BCP foca em procedimentos de recuperação, um SLA define expectativas de serviço com fornecedores, e um MOU documenta acordos entre organizações; nenhum desses é usado para registrar riscos aceitos.

Questão 6: Alternativa C — Apetite ao risco

Apetite ao risco é a quantidade e o tipo de risco que uma organização está disposta a aceitar na busca de seus objetivos. A declaração do conselho define a exposição máxima aceitável (500.000 registros) antes que uma atividade seja considerada proibida — uma definição clássica de apetite ao risco. 'Limite de evitabilidade' não é um termo padrão da CompTIA; o registro de riscos armazena riscos identificados; a tolerância ao risco residual é um conceito mais restrito aplicado após os controles, não um apetite geral de conselho.

Questão 7: Alternativa D — Mitigação e transferência

O serviço de MDR é um controle de segurança que reduz a probabilidade e o impacto dos incidentes — isso é mitigação de riscos. A apólice de seguro cibernético desloca o ônus financeiro de uma violação para um terceiro — isso é transferência de riscos. A empresa não está evitando a atividade (continua operando o e-commerce) e não está aceitando formalmente a perda sem nenhuma ação. Portanto, mitigação + transferência é a combinação correta.

Questão 8: Alternativa B — Aceitação de riscos, pois a organização assume formalmente a perda restante

A aceitação de riscos ocorre quando uma organização aceita conscientemente as consequências de um risco, geralmente porque o custo de tratamento adicional supera o benefício. O memorando de exceção assinado pelo CIO, armazenado no repositório central de riscos, é o artefato de documentação clássico da aceitação. Os controles já existentes se referem à mitigação (uma atividade anterior separada), o seguro se refere à transferência, e a decisão de não adicionar mais controles por sí só não constitui evitabilidade, a menos que a atividade em si seja interrompida.

Questão 9: Alternativa A — Mitigação de riscos, pois os controles reduzem a probabilidade e o impacto da tomada de conta

Implantar controles de segurança para reduzir a probabilidade e/ou o impacto de um risco é mitigação. Chaves de hardware, acesso condicional e o botão de reporte reduzem diretamente a probabilidade de tomada de conta — eles não

eliminam a atividade, não transferem a perda para terceiros, e os 10% restantes constituem risco residual que ainda não foi formalmente aceito. Portanto, a ação em si é mitigação.

Questão 10: Alternativa D — Transferência de riscos ao contratar um terceiro com termos de responsabilidade definidos

A transferência de riscos usa contratos, SLAs e terceirização para deslocar parte ou todo o impacto financeiro ou operacional para um terceiro. Ao contratar uma empresa de monitoramento sob um contrato que define obrigações de notificação de violação e limites de responsabilidade, a empresa de logística transfere parte da exposição ao GDPR para esse fornecedor. A implantação continua ocorrendo (não é evitabilidade), nenhum controle foi removido (não é aceitação) e a telemetria não é desativada (não é mitigação).